

Two Ways to Hold a Secret

Companion Appendices

Worked placements, threat models, standards mapping and continuous-assurance evidence

To be read alongside the main paper. Continues the appendix apparatus from C.

James Patrick CITP MBCS

Independent architecture paper · Version 1.0 · July 2026

Published under a Creative Commons Attribution 4.0 International Licence (CC BY 4.0). Vendor-neutral; described at capability level. Worked placements are illustrative and tied to no programme.

About this companion

This companion extends the reference apparatus of the main paper, **Two Ways to Hold a Secret**. Where the main paper sets out the frame - the decomposition of sovereignty into operational and cryptographic axes, the two patterns, and the decision to choose per workload and compose with discipline - this volume provides the fuller reference material that would have blunted the main argument had it been folded inline: worked workload placements, a structured threat model for each pattern, a threat-control walkthrough of the composition mechanism, an expanded standards mapping, and a catalogue of the evidence that makes the continuous-assurance claim concrete.

The main paper carries Appendices A (control vocabulary) and B (standards touchpoints). This companion continues that lettering from C, so the two documents form one body of work. Nothing here supersedes the main paper; it substantiates it. As throughout, the material is vendor- and product-neutral, and the worked examples are illustrative constructions, not descriptions of any specific system or programme.

Contents

About this companion.....	2
Contents	3
Appendix C - Worked workload placements.....	4
C.1 Two worked exemplars	5
C.2 Portfolio summary	6
C.3 The composed exemplar	6
Appendix D - Threat model: Pattern A	7
D.1 Relevant threat actors.....	7
D.2 Attack surface and control response.....	7
Appendix E - Threat model: Pattern B.....	9
E.1 Relevant threat actors	9
E.2 Attack surface and control response	9
Appendix F - Cross-domain composition: threat-control walkthrough.....	11
Appendix G - Expanded standards & controls mapping	13
Appendix H - Continuous-assurance evidence catalogue.....	15
H.1 What differs between the patterns	15

Appendix C - Worked workload placements

This appendix applies the decision framework of the main paper (Section 7.1) to a set of representative workloads, to show the reasoning in motion rather than in the abstract. Each workload is run through the ordered questions and landed on the sovereignty map. The placements are illustrative and argued at capability level; a real placement would be made against the actual classification, threat assessment and sustainment position of the organisation concerned.

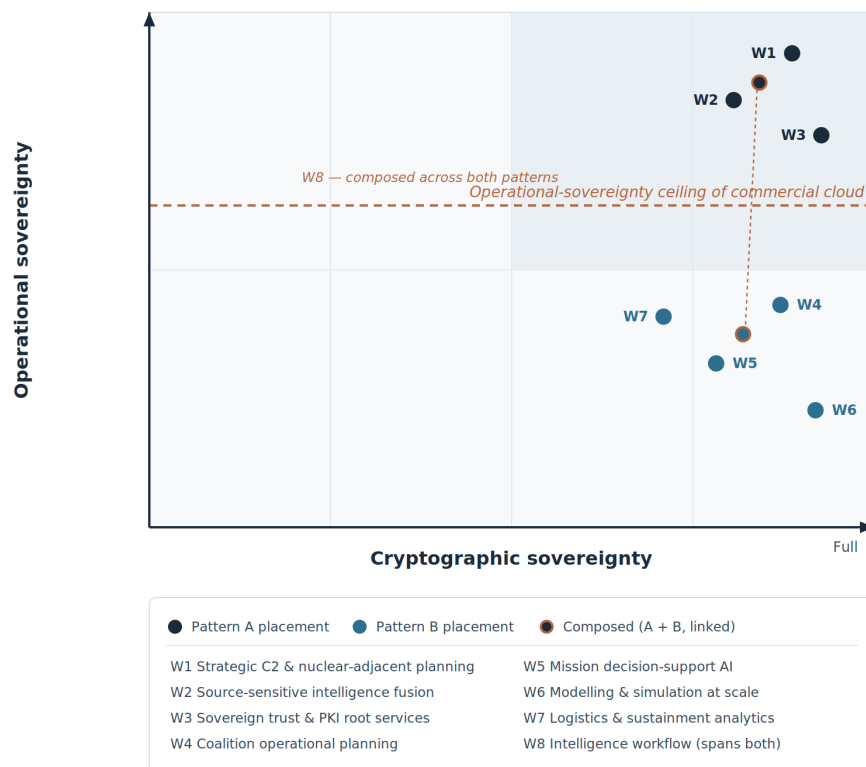
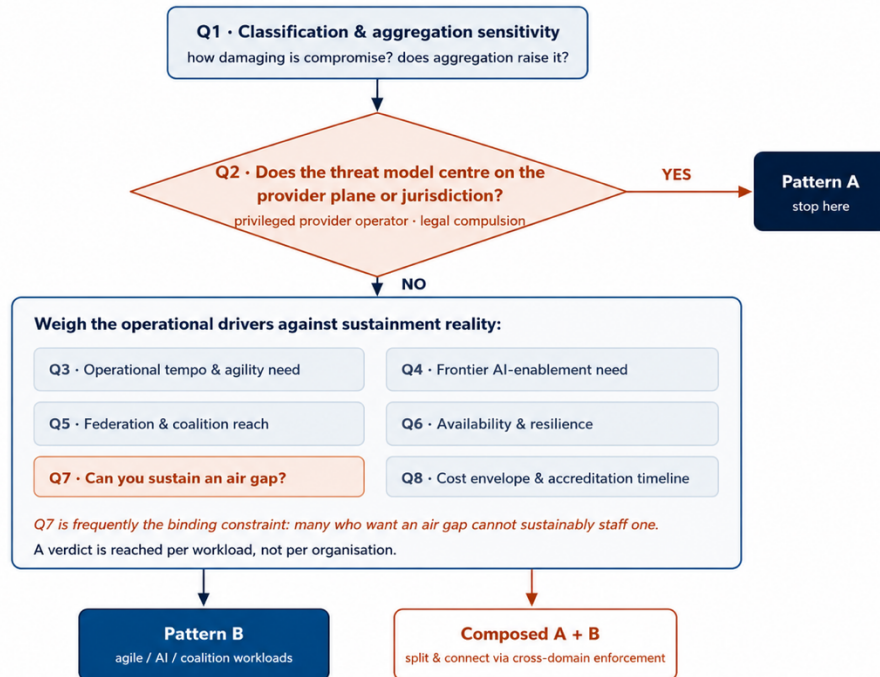


Figure C.1 - A representative portfolio placed on the sovereignty map. Pattern A workloads cluster at the top-right; Pattern B workloads sit at full cryptographic sovereignty but below the operational ceiling; a composed workload (W8) is split across both and joined by cross-domain enforcement.

Placing a workload: the ordered questions

Order matters — the second question can settle the decision on its own.



Most real estates are mixed. The framework produces a portfolio placement, not a single organisational verdict.

Figure C.2 - The ordered questions as a decision flow. The threat-model question (Q2) can settle the matter on its own; where it does not, the operational drivers are weighed against sustainment reality, and the outcome is a per-workload placement rather than an organisational verdict.

C.1 Two worked exemplars

Strategic command-and-control and nuclear-adjacent planning (W1). Question one establishes extreme sensitivity, with aggregation raising it further. Question two is decisive: the threat model explicitly includes a privileged provider operator or a legal compulsion on a provider acting against the mission, and the authority judges that possibility intolerable at any level of compensating control. The analysis stops there. This is Pattern A, and no argument from agility or cost reopens it - the early exit exists precisely so that the highest-sensitivity workloads are not talked into a public tenant by downstream convenience.

Mission decision-support AI (W5). Question one establishes real but lower sensitivity than W1. Question two returns a considered no: the workload's adversary model centres on data compromise and manipulation rather than on the provider's operational plane, and the residual provider-plane exposure can be governed to tolerance through external key custody and confidential computing. The remaining questions then pull decisively towards Pattern B: the workload depends on current, large-scale AI that is impractical behind an air gap (Q4), needs to serve distributed users at operational tempo (Q3, Q5), and could not be sustained as a bespoke air-gapped capability (Q7). It is placed in Pattern B - with the ceiling stated in its risk narrative, not hidden.

C.2 Portfolio summary

Workload	Dominant driver	Placement	Rationale (incl. Q2 outcome)
W1 Strategic C2 / nuclear-adjacent planning	Intolerable provider-plane exposure	Pattern A	Q2 = yes; early exit. Sensitivity and jurisdiction concerns override all agility arguments.
W2 Source-sensitive intelligence fusion	Source protection	Pattern A	Q2 = yes. Exposure of sources via an operator or jurisdiction is unacceptable; kept in-domain.
W3 Sovereign trust & PKI root services	Cryptographic authority	Pattern A	Trust anchors and roots held in-domain by construction; the fabric other patterns depend on.
W4 Coalition operational planning	Federation reach at tempo	Pattern B	Q2 = no. Needs multi-party interoperability at operational speed; data-centric protection travels with the payload.
W5 Mission decision-support AI	Frontier AI-enablement	Pattern B	Q2 = no. Depends on current large-scale AI impractical behind an air gap; residual governed to tolerance.
W6 Modelling & simulation at scale	Elastic compute	Pattern B	Bursty, large-scale demand suits elasticity; sensitivity manageable under crypto isolation.
W7 Logistics & sustainment analytics	Scale & agility, lower classification	Pattern B	Lower sensitivity, high agility need; a clear public-cloud fit under standard controls.
W8 Intelligence workflow spanning both	Split sensitivity profile	Composed A + B	Source-sensitive core in A, large-scale analytics/AI in B, joined by cross-domain enforcement.

Table C.1 - Illustrative portfolio placement. Most estates are mixed; the framework produces a portfolio, not a single verdict.

C.3 The composed exemplar

Workload W8 is the case that vindicates the whole matched-pair argument. An intelligence workflow has a source-sensitive fusion core whose compromise would expose collection methods - unambiguously Pattern A - and a large-scale analytic and AI-enrichment stage whose value depends on current models and elastic compute - unambiguously Pattern B. Forcing the entire workflow into one pattern would either strand the analytic stage behind an air gap where it cannot be resourced, or place the source-sensitive core in a public tenant where its adversary model says it must not go.

The composition resolves this without compromise on either side. The source-sensitive core runs in Pattern A. Selected, released products flow outward through the cross-domain enforcement chain into the Pattern B analytic environment; enriched outputs return through the same chain, revalidated on the way back before they re-enter the higher-assurance domain. Neither domain inherits native trust in the other. The workflow gets the sovereignty its most sensitive component demands and the capability its most demanding component requires - connected with discipline rather than collapsed into a single false guarantee. Appendix F treats the enforcement chain that makes this safe.

Appendix D - Threat model: Pattern A

This appendix models the residual threat surface of the air-gapped sovereign cloud - that is, the surface that **remains once physical isolation is in place**. Isolation removes a great deal, chiefly the provider plane and remote network reachability; what it does not remove deserves the same rigour, because in an isolated system the surviving vectors are where all the risk concentrates. The method is deliberately plain: relevant actors, then attack surface with the pattern's control response and the residual it leaves.

D.1 Relevant threat actors

Actor	Intent & capability	Relevance to Pattern A
Hostile state / intelligence service	Strategic collection; supply-chain and insider tradecraft; long time horizons	High - will target the few surviving ingress paths: media, updates, hardware, cleared personnel
Insider (cleared)	Privileged access; potential coercion or subversion	Elevated - privilege is concentrated in a small cleared workforce
Supply-chain adversary	Implantation in hardware, firmware or update media before the boundary	High - the gap forces the adversary upstream, where they can still reach
Physical / proximity actor	Facility access; emanations; tampering	Present - physical security becomes a primary, not secondary, control

Table D.1 - Actors whose relevance survives physical isolation.

D.2 Attack surface and control response

Vector	Pattern A control response	Residual
Media & update ingress	The cross-domain door is the sole path; content inspected, transformed and released under governance; no ad-hoc media paths permitted	Update currency lag; a determined supply-chain implant may still transit the door in an update
Firmware & hardware provenance	Provenance validation, signed artefacts, controlled procurement; measured/attested boot where available	Cannot be reduced to zero; the gap concentrates rather than removes supply-chain risk
The cross-domain door itself	Single-purpose, hardened, privately addressed; protocol break; bastion-mediated admin; full logging	The highest-value target in the pattern; failure here is the failure that matters most
Concentrated insider privilege	Separation of duties; least privilege; per-tenancy ownership; dual control on sensitive actions; session visibility	A sufficiently privileged, subverted insider remains the hardest residual to eliminate
Physical & environmental	Facility controls; emanations security; environmental resilience	Site-level single points of failure unless the environment is replicated
Operator error	Automation from tested infrastructure-as-code; change governance; presumed-breach containment	Human error persists; the design goal is that errors stay

Vector	Pattern A control response	Residual
		contained, not that they never occur
Capability opportunity-cost (threat to mission)	Recognised explicitly as a strategic risk on the register, not only a system risk	Missions unserved because the capability cannot run behind the gap - a real cost, often unrecorded

Table D.2 - The surviving vectors, the pattern's response, and what remains.

The summary judgement is that Pattern A converts a broad, remote attack surface into a narrow, concentrated one - and that this is a favourable trade only if the narrow surface is defended with corresponding intensity. The cross-domain door and the cleared workforce are not incidental details; they are where an air-gapped system lives or dies, and they must be resourced accordingly. The final row is the one most often missing from air-gap threat models: the mission that goes unserved is a genuine adverse outcome and belongs on the register alongside the technical vectors.

Appendix E - Threat model: Pattern B

This appendix models the threat surface of the SECRET-in-public pattern. It is longer than Appendix D not because the pattern is less safe but because its surface is broader and more nuanced: cryptographic isolation removes a great deal of exposure while leaving a residual that must be named precisely, culminating in the one residual no control can remove - the operational-sovereignty ceiling.

E.1 Relevant threat actors

Actor	Intent & capability	Relevance to Pattern B
Hostile state / intelligence service	Collection; legal and commercial leverage over providers; advanced technical means	High - including via jurisdiction over the provider, not only via technical attack
Privileged provider operator	Legitimate operational access to the plane; potential coercion or compromise	The defining residual actor of this pattern; the reason the ceiling exists
Legal / jurisdictional compulsion	Compels the provider to act via lawful instrument	A non-technical vector against which operational sovereignty is unavailable
Tenancy / control-plane attacker	Seeks isolation failure or plane compromise	Present; addressed by isolation, Zero Trust and monitoring, never assumed absent
Adversary of AI workloads	Prompt injection, model poisoning, retrieval manipulation	Specific to AI-enabled workloads; requires bounding the model and retrieval spaces

Table E.1 - Actors relevant to a cryptographically isolated public tenant.

E.2 Attack surface and control response

Vector	Pattern B control response	Residual
Provider read-access to data	External key custody (HYOK); non-exportable keys; ciphertext inert to the provider at rest and in transit	In-use exposure narrows to enclave residuals; availability leverage remains
Data-in-use exposure	Confidential computing / TEE with attestation of the execution context before trust	Side-channel, firmware and enclave-management residuals; exposure-reduction, not elimination
Privileged provider operator	Least-privilege plane access, monitoring, cryptographic inaccessibility of data	Irreducible: the operator runs the plane; detection is not interdiction
Legal / jurisdictional compulsion	Key custody outside the provider limits what compulsion can yield; contractual boundaries	Irreducible in operational terms; a compelled provider still operates the plane
Tenancy / control-plane compromise	Cryptographic isolation; Zero Trust; identity-aware segmentation; default-deny	Isolation failure is low-probability but high-impact; monitored, not assumed away

Vector	Pattern B control response	Residual
AI-specific (injection, poisoning, leakage)	Bounded model-interaction, retrieval, data-source and output spaces; policy-governed retrieval; output release governance	Probabilistic residual; AI behaviour is constrained, not guaranteed
Connectivity & metadata	Single controlled connectivity hub; encrypted private connectivity; connectivity treated as transport only	Operational metadata and traffic-pattern exposure to the plane is not fully removed
Future cryptographic break	Crypto-agility; readiness to migrate to post-quantum algorithms	Timing and nature of cryptanalytic advance are uncertain; agility mitigates, does not remove

Table E.2 - The public-cloud surface, the pattern's response, and what remains.

The irreducible residual.

Two rows above are marked irreducible: the privileged provider operator and legal or jurisdictional compulsion. Against these, cryptographic sovereignty is your defence and operational sovereignty is not available to you. Every other residual in the table can be driven down with more or better control; these two are structural. They are the ceiling in threat-model form.

A Pattern B risk narrative that does not name them is not merely incomplete - it is misleading to the authority that must accept the risk. Naming them is what makes the pattern accreditable.

Appendix F - Cross-domain composition: threat-control walkthrough

The composition mechanism (main paper, Section 7.2 and Figure 4) is what allows the two patterns to interoperate without conferring transitive trust. Because it is the highest-risk activity in either pattern, it warrants a stage-by-stage treatment: each enforcement stage is a control against a specific class of failure, and understanding what each stage prevents is the difference between a boundary that enforces and one that merely routes.

Stage	Threat / failure it addresses	Control behaviour	If omitted
Private ingress	Direct reachability from a lower-trust environment into the plane	No public exposure; traffic enters only through the controlled boundary	The boundary becomes bypassable; the door is no longer the only door
Protocol break	Untrusted protocol reaching internal services intact	Terminates the untrusted flow; nothing transits natively	Native transitive routing; source-side compromise reaches the destination
Inspect & transform	Malicious or non-conformant content in the payload	Content-level validation; sanitisation or transformation as required	Malicious payloads pass with the data; inspection theatre only
Release governance	Information crossing that should not, or in the wrong form	Explicit policy decision against classification, releasability and mission need	Implicit release; the boundary leaks by default
Re-origination	Source trust travelling with the data into the destination	Clean, policy-conformant output re-originated under local policy	The destination inherits source trust it never evaluated
Return-path validation	Compromised or manipulated output re-entering the higher domain	Revalidation, provenance and integrity checks on the way back	Contaminated returns flow into higher-assurance zones unchecked
Pervasive logging & telemetry	Undetected misuse or error across the chain	Every stage logged, telemetered and auditable	Cross-domain activity becomes invisible and unaccountable

Table F.1 - Each enforcement stage as a control, and the failure it prevents.

Three principles hold the walkthrough together. First, **non-transitivity**: the destination inherits only what has been explicitly released, transformed and approved - never native trust in the source domain, its transport path or its originating user. Second, **the primacy of the return path**: information coming back from a lower-trust or partner environment is conditionally trusted until revalidated, because the return direction is where malicious payload injection and policy bypass most often enter a higher-assurance domain. Third, the **separation of functions**: encryption protects the transfer, policy governs the release, inspection validates the content, and transport alone never authorises the exchange - so that the compromise of any one function is contained to that function rather than collapsing the boundary.

This is also where the main paper's counter-intuitive design rule earns its keep. Cross-domain enforcement belongs at the sovereign boundary, not inside the commercial tenant. Placing these controls where the operators are the provider's would add attack surface without adding

sovereign assurance; the enforcement is meaningful precisely because it sits under sovereign operation. The rule follows directly from the two-axis frame: a control that depends on operational sovereignty must be placed where operational sovereignty exists.

Appendix G - Expanded standards & controls mapping

This appendix maps the architectural claims of both patterns to established public standards and guidance. It is a navigation aid for assessors, not a compliance attestation: it indicates where each element is grounded, and where an assurance case would look for evidence. Standards are cited neutrally; nothing here mandates a particular product's implementation of them.

Architectural element / claim	Standards & guidance touchpoints	Notes
Zero Trust; trust not inherited from location or ownership	NIST SP 800-207	The tenet set: per-session, per-request evaluation; no implicit trust from network position
Segmentation, least privilege, default-deny	NIST SP 800-53 Rev 5 (AC, SC families)	Access-control and system/communications-protection controls; identity-aware micro-segmentation
Data-centric labelling & releasability	STANAG 4774 / 4778	Confidentiality metadata bound to the payload; the basis of policy-governed release
Cryptographic key custody & PKI	NIST SP 800-57; FIPS 140-3; SP 800-53 (SC-12, SC-17)	Key-management lifecycle; validated HSM modules; the basis of the HYOK / external-custody claim
Confidential computing & attestation	IETF RFC 9334 (RATS architecture)	Remote-attestation reference architecture; underpins 'attested before trusted', vendor-neutrally
Encryption in transit	IETF RFC 8446 (TLS 1.3); IPsec; IEEE 802.1AE (MACsec)	Transport protection across region, cross-domain and external paths
Post-quantum & crypto-agility	FIPS 203 (ML-KEM); FIPS 204 (ML-DSA); FIPS 205 (SLH-DSA); NIST SP 800-208	The basis of the future-cryptographic-risk posture; agility to migrate ahead of a relevant break
Information-security management	ISO/IEC 27001:2022; 27002; 27017; 27018	ISMS baseline; 27017/27018 add cloud-specific and PII-in-cloud control guidance
Supply-chain assurance	NIST SP 800-161; signed artefacts & SBOM practice	Provenance validation and secure build; directly relevant to both patterns' residual supply-chain risk
Logging, monitoring & audit	NIST SP 800-92; SP 800-53 (AU family)	The evidentiary basis of continuous assurance (Appendix H)
Risk appetite & acceptance	HM Treasury Orange Book	Supports calibrating tolerance differently for the two patterns while holding information-security risk very low in both
Accreditation lifecycle	NIST SP 800-37 (RMF) as a neutral analogue	Continuous-assurance evidence maps onto a risk-management-framework lifecycle

Table G.1 - Where each element is grounded. A navigation aid, not a compliance mapping.

Two observations for an assessor using this table. The post-quantum row is not a distant concern: the relevant algorithm standards are published, and the defensible posture now is crypto-agility

- an architecture able to migrate - rather than a completed migration. And the risk-appetite row is where the two-axis frame meets governance: both patterns hold information-security risk to a very low appetite, but they legitimately differ in their appetite for the operational-sovereignty exposure that only Pattern B carries, and that difference should be stated explicitly in the risk narrative rather than smoothed over.

Appendix H - Continuous-assurance evidence catalogue

The main paper claims that accreditation can be a continuous property of a running system rather than a milestone reconstructed retrospectively. That claim is only credible if the evidence actually emerges from system state. This appendix catalogues the evidence sources both patterns generate and maps them to the accreditation artefacts an authority typically expects - so that the assurance case is assembled from live telemetry rather than authored after the fact.

Evidence source (system state)	What it evidences	Maps to accreditation artefact
Infrastructure-as-code state & drift detection	That deployed reality matches the accredited design; changes are governed	System Security Plan; configuration baseline
Policy-enforcement decision logs	That default-deny and release policies are enforced, not merely declared	Zero Trust Maturity Report; control-effectiveness evidence
Identity & access telemetry	Who accessed what, under which conditions, with least privilege	Access-control evidence; Zero Trust Maturity Report
Attestation records	That platforms and workloads were in a trustworthy state before trust	Confidential-computing / integrity evidence
Vulnerability & patch state	Current exposure and remediation posture over time	Vulnerability Assessment Report
Network flow & segmentation telemetry	That segmentation holds and traffic follows authorised pathways	Data Flow Diagrams; segmentation evidence
Cross-domain release logs	Every boundary crossing: decision, transformation, return-path validation	Cross-domain assurance evidence; audit trail
Key-management & cryptographic events	Key lifecycle, custody separation and cryptographic governance	Cryptographic-sovereignty evidence (esp. Pattern B HYOK)
Monitoring & security-operations alerts	Detection, triage and response across the environment	Incident-response and continuous-monitoring evidence

Table H.1 - Evidence generated by the running system, mapped to the artefacts an authority expects.

H.1 What differs between the patterns

Both patterns generate this evidence, but they differ in one telling respect. Pattern A generates its evidence entirely in-domain, under sovereign operation, which simplifies the provenance of the assurance case. Pattern B must additionally evidence the ceiling **honestly**: it should produce positive proof of key-custody separation, attestation records for confidential-computing workloads, and a risk narrative that records - rather than obscures - the retained provider-plane and jurisdiction exposure. The evidence set for Pattern B is, in part, evidence of what the pattern does not neutralise. An assurance case that presents only the reassuring evidence and omits the retained residual is not a stronger case; it is a less trustworthy one.

Finally, control inheritance should be made explicit in both patterns. Some controls are inherited in full from the platform, some in part, and some remain local to the mission owner; stating which is which prevents the two most common accreditation errors - claiming inherited assurance that was never actually inherited, and re-evidencing controls that the platform already provides. A clear control-inheritance matrix, generated from the same live state as the rest of the evidence, is the artefact that ties the continuous-assurance claim to an auditable reality.

Companion to Two Ways to Hold a Secret. © 2026 James Patrick. Published under a Creative Commons Attribution 4.0 International Licence (CC BY 4.0). Vendor- and product-neutral; worked placements are illustrative and tied to no programme.